

Rules of Engagement for Forking a Dependency

SOSS Community Day Vienna - Sep 2024

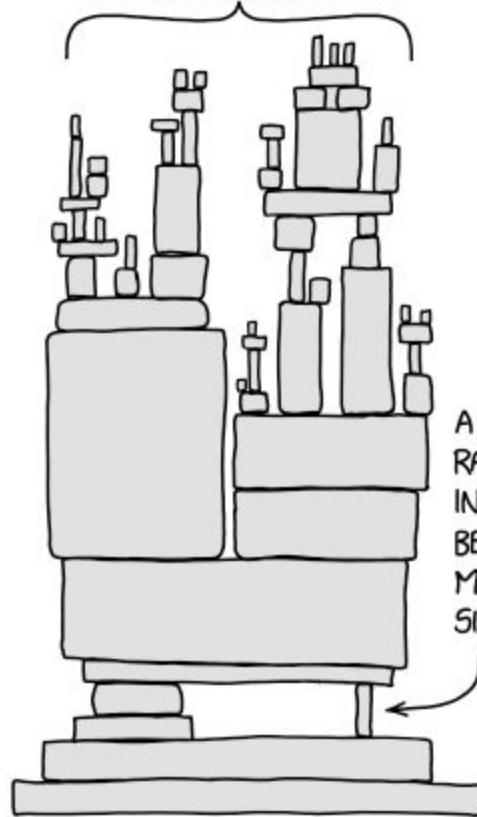




1 repository in your atsign-foundation organization might be affected by a security vulnerability in



ALL MODERN DIGITAL
INFRASTRUCTURE



A PROJECT SOME
RANDOM PERSON
IN NEBRASKA HAS
BEEN THANKLESSLY
MAINTAINING
SINCE 2003



<https://xkcd.com/2347/>

Hi, I'm Chris

@cpswan

<https://chris.swanz.net>

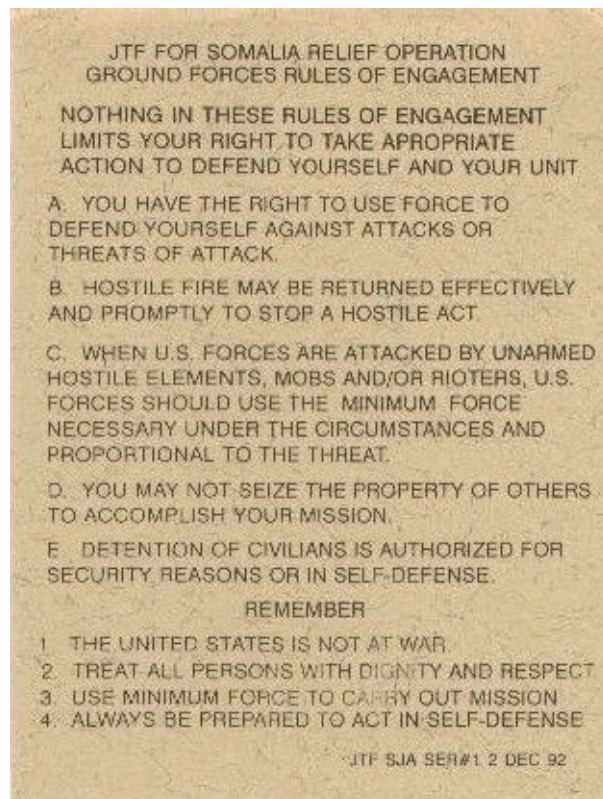


The steps

1. Check to see if there's already an issue (or PR)
2. Raise an issue
3. Submit a PR
4. Fork the repo and publish a variant



Rules of Engagement?



1. Check first



Path traversal in Archive #2



Fixed

Opened last year on [archive \(Pub\)](#) · [packages/sshnoports/pubspec.lock](#) · Fixed last year

Sep 8, 2023, 10:21 AM GMT+1

Package

archive (Pub)

Affected versions

<= 3.3.7

Patched version

3.3.8

An issue in Archive v3.3.7 allows attackers to execute a path traversal via extracting a crafted zip file.



dependabot

bot

opened this last year



dependabot

bot

closed this as completed in **#436** last year



Archive is vulnerable to symlink path traversal #265



Closed BlueSquare1 opened this issue on Jun 20, 2023 · 2 comments



BlueSquare1 commented on Jun 20, 2023 · edited

...

Hello,

while doing some security testing on `archive` package, we noticed that it supports symlinks, while symlinks might be an intended functionality of your package, we do believe that symlinks pointing outside the extraction directory are more of a security risk than a feature, below is an example where we created a symlink pointing to a file `secret.txt` in the parent directory, zipped it and extracted it using `extractFileToDisk` method from `archive` package, the symlink was created back after extraction.

```
drwxrwxr-x 2 mohamed mohamed 4096 17:08 31  .
drwxrwxr-x 7 mohamed mohamed 4096 17:07 31  ..
lrwxrwxrwx 1 mohamed mohamed 13 17:07 31  evil -> ../secret.txt
-rw-rw-r-- 1 mohamed mohamed 171 17:08 31  poc.zip
```

Screenshot from my workstation

```
drwxrws--x 6 u0_a107 u0_a107_cache 4096 2023-05-31 17:16 .
drwx----- 6 u0_a107 u0_a107 4096 2023-05-31 17:08 ..
lrwxrwxrwx 1 u0_a107 u0_a107_cache 13 2023-05-31 17:15 evil -> ../secret.txt
```

Screenshot from my test mobile device



BlueSquare1 changed the title Zip extraction recreates symlinks pointing outside the extraction directory Archive is vulnerable to symlink path traversal on Jul 24, 2023



brendan-duncan commented on Sep 1, 2023

Owner

...

I updated `extractArchiveToDisk` and `extractFileToDisk` to not create symlinks that begin with `..` or `/`, which would be outside of the extracted path.



2. Raise an issue

Unicorns :-) #1



cconstab opened this issue on Dec 26, 2019 · 3 comments



cconstab commented on Dec 26, 2019 • edited by michaelspiss ▾



Nice work but of course I had to stumble into an issue..

A pair of Unicorns break on decode... Have not figured out why as yet..

```
import 'package:utf7/utf7.dart';

main() {
  String string = "🦄🦄";
  String encoded = Utf7.encode(string);
  String strongEncoded = Utf7.encodeAll(string);
  print("UTF-7 representation: $encoded");
  print("UTF-7 representation: $strongEncoded");
  String decoded = Utf7.decode(encoded);
  print("UTF-16 representation: $decoded");
}
```





3. Raise a PR

Null safety changes #6

 Merged rinick merged 2 commits into `rinick:master` from `naresh0689:master` on Jun 29, 2021

 Conversation 0  Commits 2  Checks 0  Files changed 4



naresh0689 commented on Jun 29, 2021

Contributor ...

Hi,

I made changes to make the base2e15 dart package null safe. Please review and approve the PR.

Thanks,

Naresh



 naresh0689 added 2 commits 3 years ago

  Null safety changes

bdb7b92

  changelog

f8f9f88



rinick merged commit `b8d70cb` into `rinick:master` on Jun 29, 2021

Revert





4. (Reluctantly) Fork (and publish a variant)





at-dart-utf7

Public



Edit Pins ▾



Watch 2

forked from [michaelspiss/dart-utf7](#)



trunk ▾



3 Branches



2 Tags



Go to file



<> Code ▾

This branch is 3 commits ahead of [michaelspiss/dart-utf7:master](#) .



Contribute ▾



Sync fork ▾



at_utf7 1.0.0

Published 3 years ago Dart 3 compatible

[SDK](#)[DART](#)[FLUTTER](#)[PLATFORM](#)[ANDROID](#)[IOS](#)[LINUX](#)[MACOS](#)[WEB](#)[WINDOWS](#) 0[Readme](#)[Changelog](#)[Installing](#)[Versions](#)[Scores](#)

Provides methods to encode/decode utf-7 strings or adapt the modified base64 for custom methods.



The steps

1. Check to see if there's already an issue (or PR)
2. Raise an issue
3. Submit a PR
4. Fork the repo and publish a variant



Resources

Blog post:

<https://blog.atsign.dev/steps-before-forking>



Thanks for your time

chris@atsign.com

@cpswan



Questions?